SOC/L1 - 4.1. Pyramid of Pain

Task 1 - Introduction

The **Pyramid of Pain** is a cybersecurity concept used in **Threat Hunting, Incident Response (IR), and Cyber Threat Intelligence (CTI)** to improve detection capabilities. It explains that defenders should move beyond **IOC-based detection** (such as malware hashes, IP addresses, and domains) and focus on **behavior-based detection**, including attacker **Tactics, Techniques, and Procedures (TTPs)**.

- **IOCs (Hashes, IPs, Domains):** Easy for attackers to change and replace, causing minimal disruption.
- **TTP-based Detection:** Harder for attackers to modify because it represents their methods and behaviors.

The key principle is:

The harder something is for an attacker to change, the more pain they experience when defenders detect it.

By focusing on attacker behaviors rather than individual indicators, SOC analysts, threat hunters, and incident responders can build more resilient security detections and improve their ability to identify advanced threats.

Task 2 - Hash Values (Trivial)

A **hash value** is a fixed-length numeric or hexadecimal value generated by a **hashing algorithm** that uniquely identifies data, such as files or malware samples.

- **MD5 (Message Digest):** Produces a **128-bit hash value**. It is widely used but is **no longer secure** due to hash collision vulnerabilities.
- SHA-1 (Secure Hash Algorithm 1): Produces a **160-bit hash value** (40 hexadecimal characters). It has been **deprecated by NIST** due to collision and brute-force weaknesses.
- **The SHA-2 (Secure Hash Algorithm 2):** Developed as a replacement for SHA-1. **SHA-256** is the most common variant, producing a **256-bit hash value** (64 hexadecimal characters) and is considered secure.

Security professionals use hashes to:

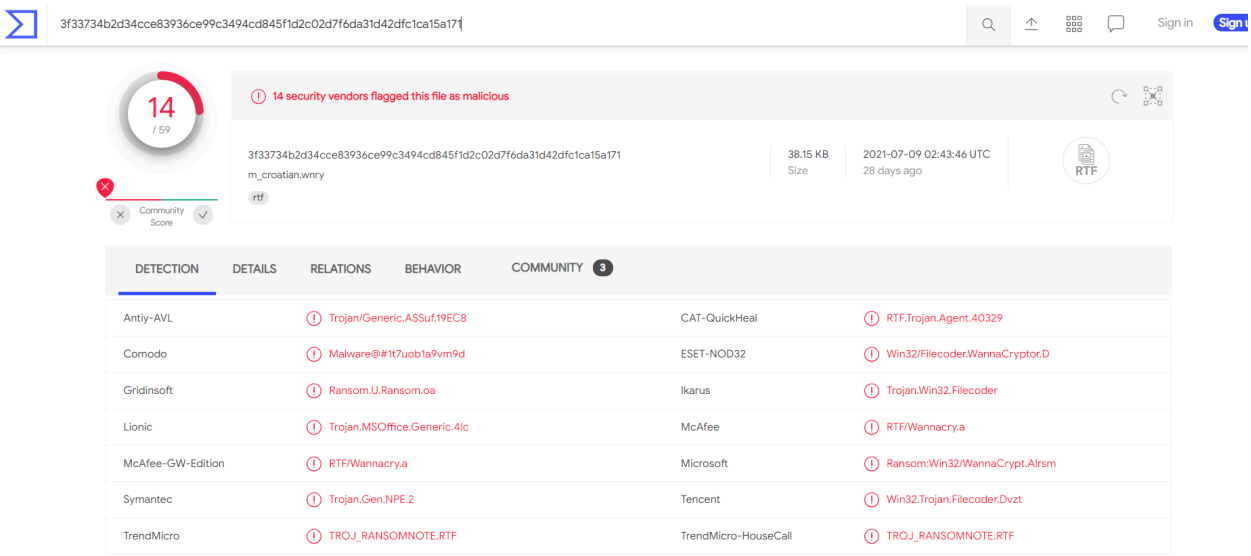
- Identify and track **malware samples** and suspicious files.
- Perform **threat intelligence investigations**.
- Create **IOC-based detections** in security tools.
- Reference malicious artifacts in malware reports.

A hash is **not secure** if two different files can generate the same hash value (**hash collision**). Hashes are valuable **Indicators of Compromise (IOCs)** for identifying known malicious files, but attackers can easily modify malware to change its hash. Therefore, modern detection focuses increasingly on **behavior and TTPs** rather than only hashes.

Hash Lookup Tools: Security analysts commonly use online platforms to investigate file hashes, such as:

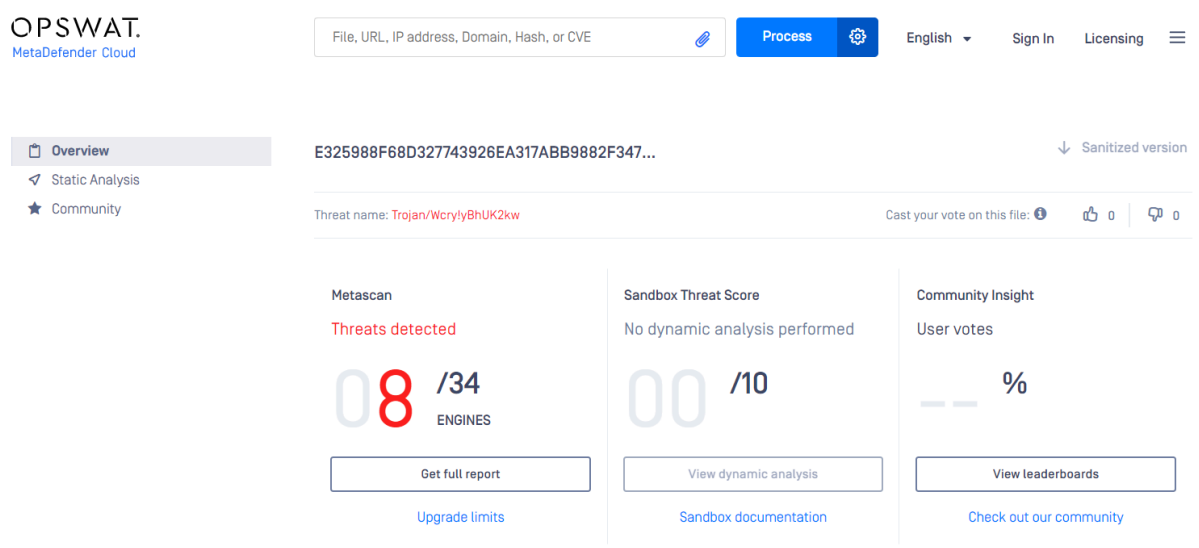
- VirusTotal
- OPSWAT MetaDefender Cloud

VirusTotal:



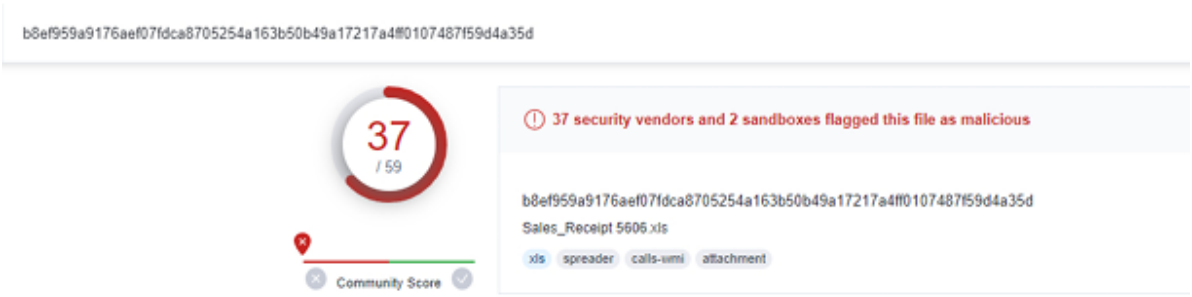
Below the hash in the screenshot above, you can see the filename. In this case, it is "m_croetian.wnry"

MetaDefender Cloud - OPSWAT:



> Analyse the report associated with the hash "b8ef959a9176aef07fdca8705254a163b50b49a17217a4ff0107487f59d4a35d" here. What is the filename of the sample?

Sales_Receipt 5606.xls



Task 3 - IP Address (Easy)

IP addresses are used to identify devices connected to a network and enable communication between systems. In the **Pyramid of Pain**, IP addresses are classified as a lower-level indicator because attackers can easily change them. From a defensive perspective, blocking malicious IP addresses using firewalls can help prevent attacks, but this method is not highly effective because attackers can quickly switch to new IP addresses. Attackers often use **Fast Flux**, a DNS technique that associates multiple changing IP addresses with a single domain. This helps hide phishing sites, malware delivery systems, and **Command and**

Control (C2) servers, making detection and blocking more difficult. IP-based detection is useful but limited because attackers can easily modify their infrastructure. Behavioral detection and TTP-based analysis provide stronger long-term defense.

HTTP Requests 0 | Connections 4 | DNS Requests 4 | Threats 0

Timeshift	Protocol	Rep	PID	Process name	CN	IP	Port
85528 ms	TCP	⚠	1632	some_malicious_file.bi...	🇺🇸	50.87.136.52	443
144.95 s	TCP	?	1632	some_malicious_file.bi...	🇩🇪	78.46.1.42	443
205.35 s	TCP	⚠	1632	some_malicious_file.bi...	🇩🇪	134.119.253.108	443
264.76 s	TCP	⚠	1632	some_malicious_file.bi...	🇺🇸	104.21.87.185	443

> Read the following report to answer this question. What is the first IP address the malicious process (PID 1632) attempts to communicate with?

50.87.136.52

Network activity

Add for printing

HTTP(S) requests	TCP/UDP connections	DNS requests	Threats
0	4	4	0

HTTP requests

No HTTP requests

Download PCAP, analyze network streams, HTTP content and a lot more at the full report

Connections

PID	Process	IP	Domain	ASN	CN	Reputation
1632	some_malicious_file.bin.exe	50.87.136.52:443	craftingalegacy.com	Unified Layer	US	suspicious
1632	some_malicious_file.bin.exe	78.46.1.42:443	g2mediainc.com	Hetzner Online GmbH	DE	suspicious
1632	some_malicious_file.bin.exe	104.21.87.185:443	vipcarrental.ae	Cloudflare Inc	US	suspicious
1632	some_malicious_file.bin.exe	134.119.253.108:443	brinkdoepke.eu	Host Europe GmbH	DE	suspicious

> Read the following report to answer this question. What is the first domain name the malicious process ((PID 1632) attempts to communicate with?

craftingalegacy.com

Task 4 - Domain Names (Simple)

Domain names map IP addresses to human-readable names (e.g., `evilcorp.com`). In the **Pyramid of Pain**, domain names are more difficult for attackers to change than IP addresses because they must register new domains and modify DNS records. However, attackers can still quickly change domains using flexible DNS providers and APIs.

Attackers use techniques like **Punycode attacks** to create malicious domains that look similar to legitimate websites. Punycode converts Unicode characters into ASCII format, allowing attackers to create lookalike domains for phishing campaigns.

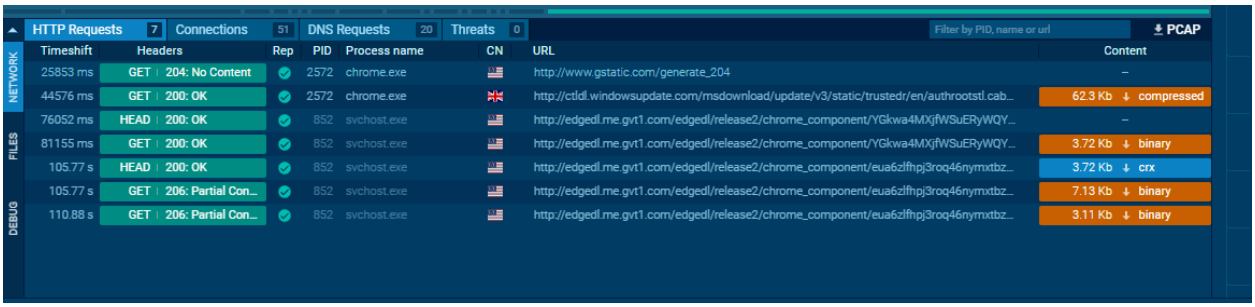
Attackers also use **URL shorteners** to hide malicious links and make detection harder. Security analysts can investigate shortened URLs by checking their redirect destinations.

Tools like **Any.Run** help analysts analyze malware behavior by monitoring:

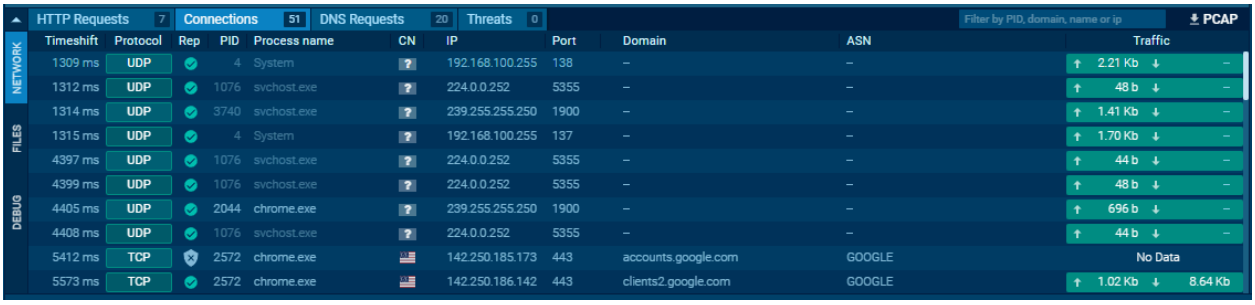
- **HTTP requests** – Shows web traffic and resources accessed by malware.
- **Network connections** – Reveals communication with external hosts, such as C2 servers.
- **DNS requests** – Shows domain lookups made by malware, often used for command-and-control communication or internet connectivity checks.

"Punycode is a way of converting words that cannot be written in ASCII, into a Unicode ASCII encoding."

HTTP Requests: This tab shows the recorded HTTP requests since the detonation of the sample. This can be useful to see what resources are being retrieved from a webserver, such as a dropper or a callback.

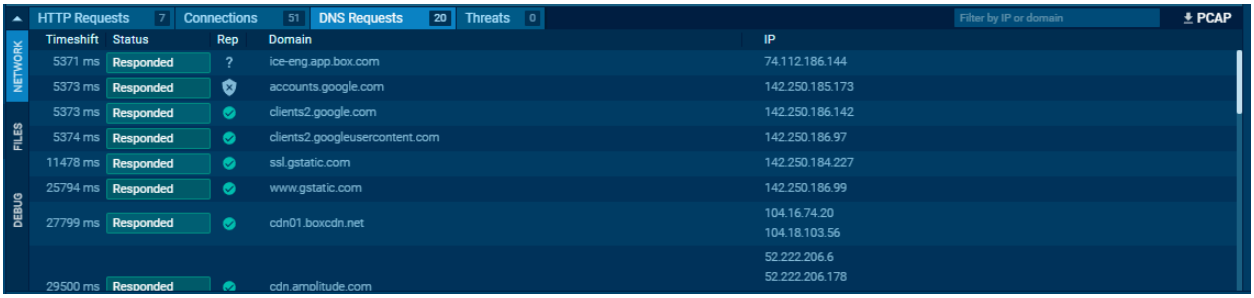


Connections: This tab shows any communications made since the detonation of the sample. This can be useful to see if a process communicates with another host. For example, this could be C2 traffic, uploading/downloading files over FTP, etc.



Timeshift	Protocol	Rep	PID	Process name	CN	IP	Port	Domain	ASN	Traffic
1309 ms	UDP		4	System		192.168.100.255	138	–	–	2.21 Kb
1312 ms	UDP		1076	svchost.exe		224.0.0.252	5355	–	–	48 b
1314 ms	UDP		3740	svchost.exe		239.255.255.250	1900	–	–	1.41 Kb
1315 ms	UDP		4	System		192.168.100.255	137	–	–	1.70 Kb
4397 ms	UDP		1076	svchost.exe		224.0.0.252	5355	–	–	44 b
4399 ms	UDP		1076	svchost.exe		224.0.0.252	5355	–	–	48 b
4405 ms	UDP		2044	chrome.exe		239.255.255.250	1900	–	–	696 b
4408 ms	UDP		1076	svchost.exe		224.0.0.252	5355	–	–	44 b
5412 ms	TCP		2572	chrome.exe		142.250.185.173	443	accounts.google.com	GOOGLE	No Data
5573 ms	TCP		2572	chrome.exe		142.250.186.142	443	clients2.google.com	GOOGLE	1.02 Kb / 8.64 Kb

DNS Requests: This tab shows the DNS requests made since the detonation of the sample. Malware often makes DNS requests to check for internet connectivity.



Timeshift	Status	Rep	Domain	IP
5371 ms	Responded	?	ice-eng.app.box.com	74.112.186.144
5373 ms	Responded		accounts.google.com	142.250.185.173
5373 ms	Responded		clients2.google.com	142.250.186.142
5374 ms	Responded		clients2.googleusercontent.com	142.250.186.97
11478 ms	Responded		ssl.gstatic.com	142.250.184.227
25794 ms	Responded		www.gstatic.com	142.250.186.99
27799 ms	Responded		cdn01.boxcdn.net	104.16.74.20 104.18.103.56
29500 ms	Responded		cdn.amplitude.com	52.222.206.6 52.222.206.178

Answer the questions below

Go to this report on app.any.run (opens in new tab) and provide the first suspicious domain request you are seeing, you will be using this report to answer the remaining questions of this task. craftingalegacy.com

> What term refers to an address used to access websites? Domain Name

> What type of attack uses Unicode characters in the domain name to imitate the a known domain? Punycode attack

> Provide the redirected website for the shortened URL using a preview: https://tinyurl.com/bw7t8p4uhttps://tryhackme.com/ https://tinyurl.com/bw7t8p4u + (to see that put + aign at the end of url)

Task 5 - Host Artifacts (Annoying)

Artifacts : In cybersecurity, **artifacts** are **traces, evidence, or observable data left behind by users, attackers, malware, or system activities**. Security analysts examine these artifacts during **incident response, digital forensics, and threat hunting** to identify suspicious behavior and investigate attacks.

Host artifacts are the traces or observables that attackers leave on the system, such as registry values, suspicious process execution, attack patterns or IOCs (Indicators of Compromise), files dropped by malicious applications, or anything exclusive to the current threat.

Host artifacts are traces left by attackers on a compromised system, such as registry changes, suspicious processes, malicious files, attack patterns, or other **Indicators of Compromise (IOCs)**. In the **Pyramid of Pain**, detecting host artifacts causes more frustration for attackers because they must change their tools, techniques, and methods. This requires more time, effort, and resources to bypass detection. Host artifact detection provides stronger defense because attackers must modify their attack approach instead of simply changing IP addresses or domains.

Suspicious process execution from Word:

WINWORD.EXE	0.01	51,500 K	134,300 K	3640 Microsoft Word	Microsoft Corporation
api-ms-win-downlevel-user32-l1-...		4,632 K	11,192 K	3300 EffectDemo MFC Application	

Suspicious events followed by opening a malicious application:

Time o...	Process Name	PID	Operation	Path	Result
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS
3:24:26....	POwersheLL.exe	3540	WriteFile	C:\Users\RussianPanda\Jehhzda\Ben14fr\G_jugk.exe	SUCCESS
3:24:26....	POwersheLL.exe	3540	TCP Receive	192.168.75.222:1047 -> 35.214.215.33:80	SUCCESS

The files modified/dropped by the malicious actor:

2728	WINWORD.EXE	C:\Users\admin\AppData\Local\Temp\VBE\MSForms.exd		tlb
		MD5: CC11BFD14D6ECC83477B69FF06C6C587	**SHA256:** A4E8F5821887AC26449C33D9B027CE31BE0E7203DD035C5DC7D34A9AEF01A6DA	
2728	WINWORD.EXE	C:\Users\admin\AppData\Local\Temp\~$O-100120 CDW-102220.doc		pgc
		MD5: 2E7A3442236F2D50C669BC79188BBD69	**SHA256:** BF007001BACF8F6ABF371B0B2797B7D13B741879E1E5B76FB616A934318418A9	
3828	POwersheLL.exe	C:\Users\admin\Jehhzda\Ben14fr\G_jugk.exe		executable
		MD5: 92F58C4E2F524EC53EBE10D914D96CCB	**SHA256:** 4A9E32BC5348265C43945ADAAF140B98B64329BD05878BC13671FA916F423710	
1640	G_jugk.exe	C:\Users\admin\AppData\Local\photowiz\regidle.exe		executable
		MD5: 92F58C4E2F524EC53EBE10D914D96CCB	**SHA256:** 4A9E32BC5348265C43945ADAAF140B98B64329BD05878BC13671FA916F423710	

Answer the questions below

> A process named regidle.exe makes a POST request to an IP address based in the United States (US) on port 8080. What is the IP address? 96.126.101.6

Network activity

HTTP(S) requests	TCP/UDP connections	DNS requests	Threats
18	25	4	27

HTTP requests

PID	Process	Method	HTTP Code	IP	URL	CN	Type	Size	Reputation
3164	regidle.exe	POST	–	200.116.145.225:443	http://200.116.145.225:443/x4VtVzvRhVPEyfB/Xq02AK6oEVt/	CO	–	–	malicious
3164	regidle.exe	POST	–	96.126.101.6:8080	http://96.126.101.6:8080/VDpVH/OUmWd7VBXpU7L/VxWuduF/zT560LD/f6oH6uVWDWqAsckvA/U3LgE/	US	–	–	malicious
3828	POwershelL.exe	GET	404	69.65.3.162:80	http://eubanks7.com/administrator/ubdDbB/	US	html	315 b	suspicious
3828	POwershelL.exe	GET	200	35.214.215.33:80	http://lidoraggiodisole.it/cgi-bin/zLG879/	US	executable	368 Kb	malicious
3164	regidle.exe	POST	404	5.196.108.185:8080	http://5.196.108.185:8080/VznUAWLqj/pARcFNvv/EWIHClKKbva6/zQVAdPyKoQYwu/G2AcsRRGqJEa3/QNV1u3DgLR5dntG/	FR	html	564 b	malicious
3164	regidle.exe	POST	–	167.114.153.111:8080	http://167.114.153.111:8080/OxYV/8zgZloGYStRl/JkBOOBe/HRAZSzsYY/9IpMzzRmtoHM/	CA	–	–	malicious
3164	regidle.exe	POST	–	194.187.133.160:443	http://194.187.133.160:443/Nqdlz/w2BG/	BG	–	–	malicious
3164	regidle.exe	POST	–	103.86.49.11:8080	http://103.86.49.11:8080/VCvOqXMjgEehauu/AyEp/O9Qn2/R6Rj7Gw9eOv6yJ/fC5a36YfopGe/Q2AwYvSohZiyaEtbbo/	TH	–	–	malicious
3164	regidle.exe	POST	–	98.174.164.72:80	http://98.174.164.72/ghMuzyNCNWN/kMmYdVIthxeVy/o2feo8eu7Jyv/O2M8WIf9SpyCp/yLVEV96eosyd5URJ477/8wdGXdz9k9hhJ/Wp/	US	–	–	malicious

> The actor drops a malicious executable (EXE). What is the name of this executable? (Host artifact) G_jugk.exe

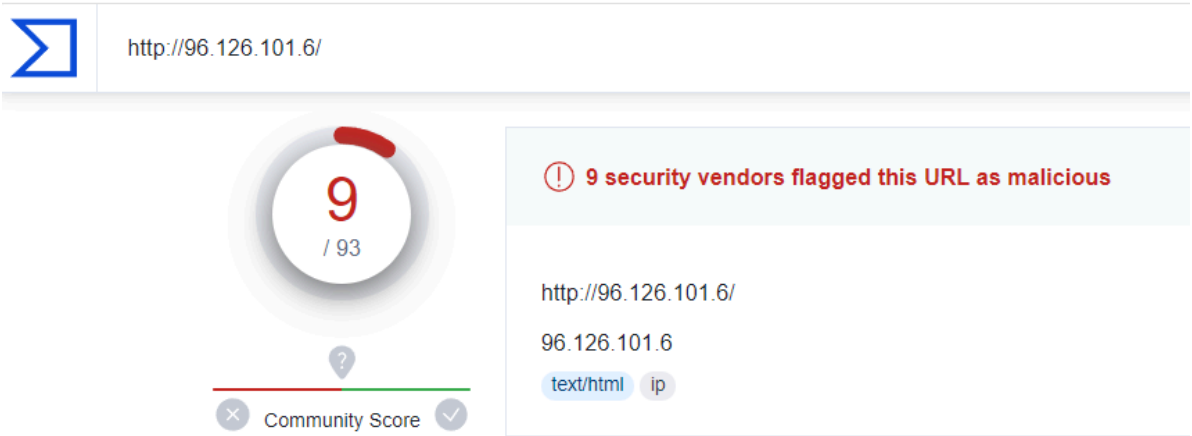
Files activity

Executable files	Suspicious files	Text files	Unknown types
2	3	0	3

Dropped files

PID	Process	Filename	Type
2728	WINWORD.EXE	C:\Users\admin\AppData\Local\Temp\CVR442C.tmp.cvr MD5: – SHA256: –	–
3828	POwershelL.exe	C:\Users\admin\AppData\Roaming\Microsoft\Windows\Recent\CustomDestinations\d93f411851d7c929.customDestinations-ms MD5: FF2E5687F6AE82AD7D5766EF1959944F SHA256: B4985E762E7471F122F8D6A9B7FF91E810B644CB827469EA77736E5A6107ED01	binary
3828	POwershelL.exe	C:\Users\admin\AppData\Roaming\Microsoft\Windows\Recent\CustomDestinations\FIT0N66RBH0VW9F6ARSX.temp MD5: FF2E5687F6AE82AD7D5766EF1959944F SHA256: B4985E762E7471F122F8D6A9B7FF91E810B644CB827469EA77736E5A6107ED01	binary
2728	WINWORD.EXE	C:\Users\admin\AppData\Roaming\Microsoft\Templates\~$Normal.dotm MD5: 4755537944AFCEFEC9B9C775CB4B7A133 SHA256: EDA472127C813AD9BAE1D0D5575D8FAA2B95568639563D81408EDB4C71962BA5	pgc
3828	POwershelL.exe	C:\Users\admin\AppData\Roaming\Microsoft\Windows\Recent\CustomDestinations\d93f411851d7c929.customDestinations-ms~RF2b495c.TMP MD5: FF2E5687F6AE82AD7D5766EF1959944F SHA256: B4985E762E7471F122F8D6A9B7FF91E810B644CB827469EA77736E5A6107ED01	binary
2728	WINWORD.EXE	C:\Users\admin\AppData\Local\Temp\VBE\MSForms.exd MD5: CC11BFD14D6ECC83477B69FF06C6C587 SHA256: A4E8F5821887AC26449C33D9B027CE31BE0E7203DD035C5DC7D34A9AEF01A6DA	tlb
2728	WINWORD.EXE	C:\Users\admin\AppData\Local\Temp\~$O-100120 CDW-102220.doc MD5: 2E7A3442236F2D50C669BC79188BBD69 SHA256: BF007001BACF8F6ABF371B0B2797B7D13B741879E1E5B76FB616A934318418A9	pgc
3828	POwershelL.exe	C:\Users\admin\Jehhzda\Ben14fr\G_jugk.exe MD5: 92F58C4E2F524EC53EBE10D914D96CCB SHA256: 4A9E32BC5348265C43945ADAAF140B98B64329BD05878BC13671FA916F423710	executable
1640	G_jugk.exe	C:\Users\admin\AppData\Local\photowiz\regidle.exe MD5: 92F58C4E2F524EC53EBE10D914D96CCB SHA256: 4A9E32BC5348265C43945ADAAF140B98B64329BD05878BC13671FA916F423710	executable

> Look at this report by VirusTotal. How many vendors determine this host to be malicious? 9



Task 6 - Network Artifacts (Annoying)

Network Artifacts also belong to the yellow zone in the Pyramid of Pain. This means if you can detect and respond to the threat, the attacker would need more time to go back and change his tactics or modify the tools, which gives you more time to respond and detect the upcoming threats or remediate the existing ones.

A network artifact can be a user-agent string, C2 information, or URI patterns followed by the HTTP POST requests.An attacker might use a User-Agent string that hasn't been observed in your environment before or seems out of the ordinary. The User-Agent is defined by RFC2616(opens in new tab) as the request-header field that contains the information about the user agent originating the request.

Network artifacts can be detected in PCAPs (file that contains the network packet dumps) by using a tool such as Wireshark or TShark, or exploring IDS (Intrusion Detection System) alerts from a tool such as Snort(opens in new tab). You will learn these tools in the following rooms, but in short, imagine a list of suspicious HTTP POST requests:

```
192.168.100.140      194.187.133.160        936 HTTP    POST /Nqdlz/w2BG/ HTTP/1.1
192.168.100.140      98.174.164.72          936 HTTP    POST /ghMuzyNCNWN/kMmYdVIthxeVy/o2feo8eu7Jyv/O2M8WIf9SpyCp/yLVEV96eosyd5URJ477/8wdGXdz9k9hhJjWp/ HTTP/1.1
192.168.100.140      103.86.49.11           936 HTTP    POST /VCvOqXMjgEehauu/AyEp/O9Qn2/R6Rj7Gw9eOv6yJ/fC5a36YfopGe/Q2AwYvSohZiyaEtbbo/ HTTP/1.1
192.168.100.140      78.24.219.147          904 HTTP    POST /jCOc/oQQPMafJlpMi6n3/Pbao/K7oB22aAUKQ6lA6r/GoOMY/ HTTP/1.1
192.168.100.140      50.245.107.73          888 HTTP    POST /ukXcIsljsvd7W/h2VQlYqB/csuQkgUqlkakMvQRJ9/NCjJodG/ HTTP/1.1
192.168.100.140      110.145.77.103         888 HTTP    POST /QZvVQ6o1I/DYk9QgXU/HtoxMCRHbYCJhgamW/5NsCejn3/ HTTP/1.1
```

It's hard to attribute the requests to a specific malware from the first glance, but you can dig deeper and look for its network indicators, such as the **User-Agent**. In TShark, you could use the following command:

- `tshark --Y http.request -T fields -e http.host -e http.user_agent -r analysis_file.pcap`

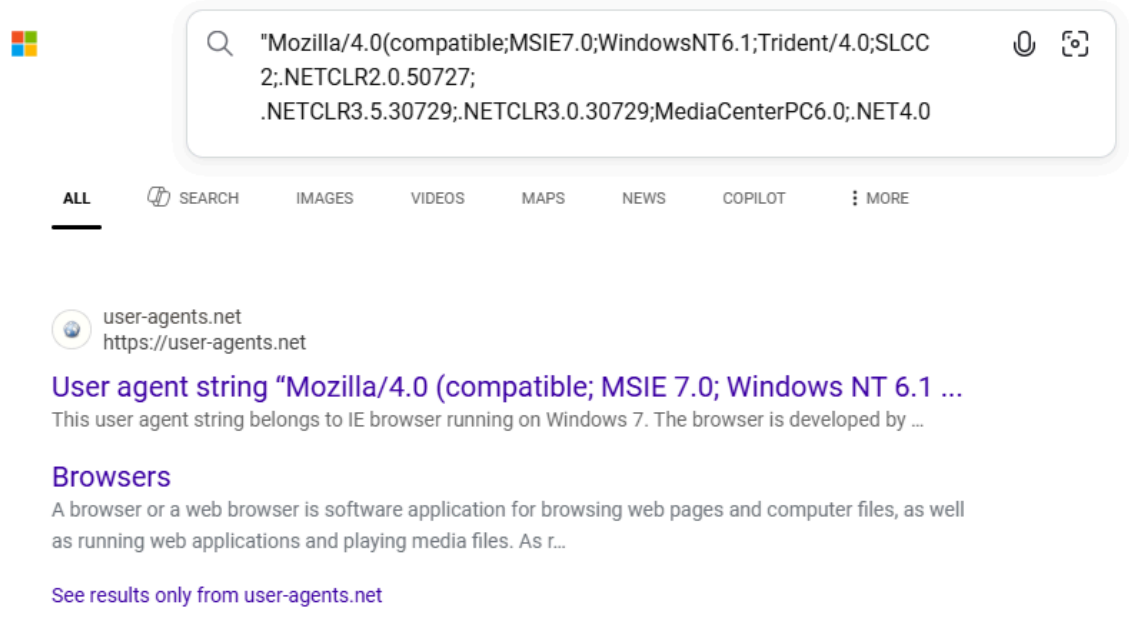
```
┌──(kali㉿kali)-[~/Desktop]
└─$ tshark -Y http.request  -T fields -e http.user_agent -r analysis.pcap


Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E)
```

These are the most common User-Agent strings found for the Emotet(opens in new tab) trojan. If you can detect the custom User-Agent strings that the attacker is using, you might be able to block them, creating more obstacles and making their attempt to compromise the network more annoying.

Answer the questions below

> Which network indicator helped us identify the malware type (Emotet)? User-Agent (google the string)



> How many POST requests are in the screenshot from the PCAP file? 6

192.168.100.140	194.187.133.160	936	HTTP	POST /Nqdlz/w2BG/ HTTP/1.1
192.168.100.140	98.174.164.72	936	HTTP	POST /ghMuzyNCNWN/kMmYdVIthxeVy/o2feo8eu7Jyv/O2M8WIf9SpyCp/yLVEV9
192.168.100.140	103.86.49.11	936	HTTP	POST /VCvOqXMjgEehauu/AyEp/O9Qn2/R6Rj7Gw9eOv6yJ/fC5a36YfopGe/Q2Aw
192.168.100.140	78.24.219.147	904	HTTP	POST /jCOc/oQQPMafJlpMi6n3/Pbao/K7oB22aAUKQ6lA6r/GoOMY/ HTTP/1.1
192.168.100.140	50.245.107.73	888	HTTP	POST /ukXcIsljsvd7W/h2VQlYqB/csuQkgUqlkakMvQRJ9/NCjJodG/ HTTP/1.1
192.168.100.140	110.145.77.103	888	HTTP	POST /QZvVQ6o1I/DYk9QgXU/HtoxMCRHbYCJhgamW/5NsCejn3/ HTTP/1.1

Task 7 - Tools (Challenging)

At the **Tools** level of the Pyramid of Pain, defenders can detect and identify the specific tools attackers use. This creates more difficulty for attackers because they must develop new tools, find alternatives, or gain new skills to continue their operations.

Attackers commonly use tools to:

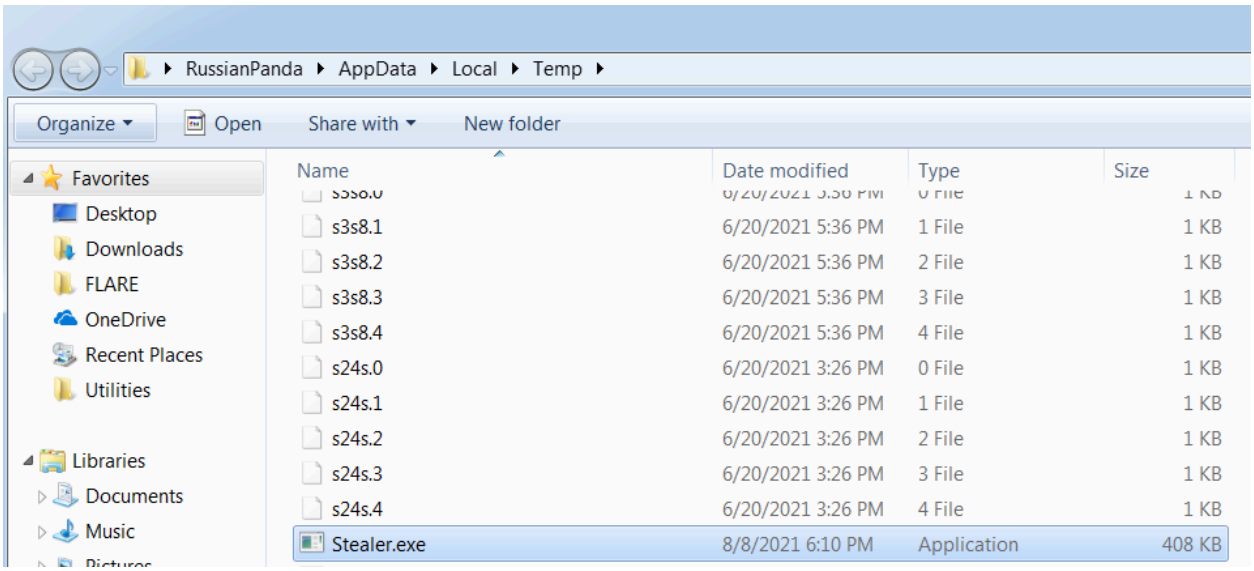
- Create malicious documents (**maldocs**) for spear-phishing.
- Build backdoors for **Command and Control (C2)** communication.
- Generate custom **EXE/DLL files**, payloads, and password-cracking tools.

Security teams can detect these tools using:

- **Antivirus signatures**
- **Detection rules**
- **YARA rules**
- Threat intelligence sources such as **MalwareBazaar** and **Malshare**

Threat hunters can also use **fuzzy hashing** (e.g., **SSDeep**) to perform similarity analysis and identify modified versions of malware even when small changes have been made.

A Trojan dropped the suspicious "Stealer.exe" in the Temp folder:



The execution of the suspicious binary:

Fuzzy hashing is to perform similarity analysis and identify modified versions of malware even when small changes have been made.

Example of SSDeep from VirusTotal:

DETECTION | DETAILS | RELATIONS | BEHAVIOR | COMMUNITY 13+

Basic Properties

MD5	9498ff82a64ff445398c8426ed63ea5b
SHA-1	36f9ca40b3ce96fcee1cf1d4a7222935536fd25b
SHA-256	8b2e701e91101955c73865589a4c72999aeabc11043f712e05fdb1c17c4ab19a
Vhash	025056657d755510804011z9005b9z25z12z3afz
Authentihash	ad56160b465f7bd1e7568640397f01fc4f8819ce6f0c1415690ecee646464cec
Imphash	d7584447a5c5ca9b4a55946317137951
Rich PE header hash	fa4dbca9180170710b3c245464efa483
SSDEEP	6144:Gz90qLc1zR98hUb4UdjzEwG+vqAWiR4EXePbix67CNzjX:Gz90qLc1lWhUbhVqJPbiQ7CNzb
TLSH	T1DB44CF267660D833D0DF94316C75C3F9673BFC2123215A6B6A4417699E307E0AE7839E
File type	Win32 EXE
Magic	PE32 executable for MS Windows (GUI) Intel 80386 32-bit
TrID	Win32 Executable MS Visual C++ (generic) (48.8%)
TrID	Win64 Executable (generic) (16.4%)
TrID	Win32 Dynamic Link Library (generic) (10.2%)
TrID	Win16 NE executable (generic) (7.8%)
TrID	Win32 Executable (generic) (7%)
File size	249.00 KB (254976 bytes)

Answer the questions below

> Provide the method used to determine similarity between the files. Fuzzy Hashing

> Provide the alternative name for fuzzy hashes without the abbreviation context triggered piecewise hashes ssdeep - Fuzzy hashing program

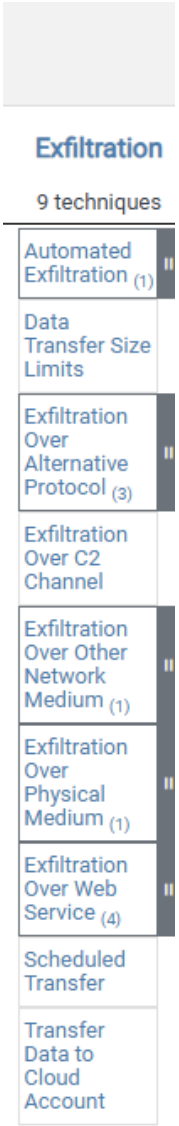
Task 8 - TTPs (Tough)

TTPs stand for **Tactics, Techniques, and Procedures** and describe the complete methods attackers use to achieve their objectives. They include activities covered in the **MITRE ATT&CK Framework**, from initial access techniques like **phishing** to **persistence, lateral movement, and data exfiltration**. Detecting and responding to attacker **TTPs** is one of the strongest defense strategies because attackers must significantly change their behavior and methods to bypass detection.

A **Pass-the-Hash attack allows attackers to use stolen password hashes as authentication tokens**, enabling lateral movement without needing the actual password.

Answer the questions below

> Navigate to ATT&CK Matrix webpage. How many techniques fall under the Exfiltration category? 9

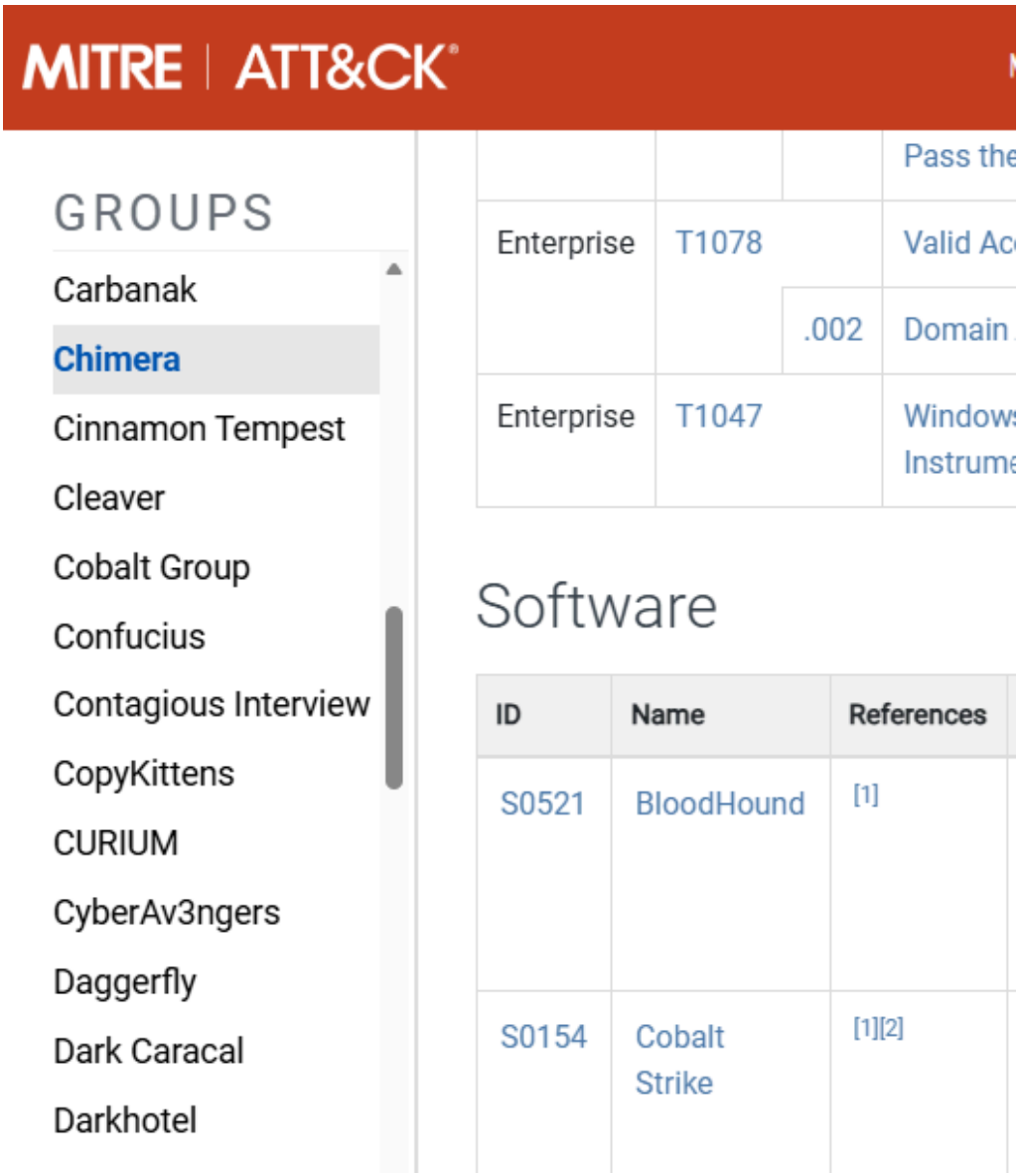


From left to right based on the **attacker's attack lifecycle** (tactics). Each column represents a **Tactic**, which describes the attacker's goal at that stage. **Under each tactic, Techniques** and **Sub-techniques** that describe *how* attackers achieve those goals.

A **Cobalt Strike attack** refers to the misuse of the **Cobalt Strike framework** by threat actors to control compromised systems, perform post-exploitation activities, and move deeper into a target network.

Rapid7 is a **cybersecurity company** that provides security solutions for **vulnerability management, SIEM, threat detection, and incident response**

> Chimera is a China-based hacking group that has been active since 2018. What is the name of the commercial, remote access tool they use for C2 beacons and data exfiltration? Cobalt Strike



Task 9 - Practical: The Pyramid of Pain

Deploy the static site attached to this task

Answer the questions below

> Complete the static site. What is the flag? THM{PYRAMIDS_COMPLETE}

Tools
The attacker has utilised these to accomplish their objective.
TTP
The attackers plans and objectives.
Hash values
These signatures can be used to attribute payloads and artefacts to an actor.
Domain Names
An attacker has purchased this and used it in a typo-squatting campaign.
IP addresses
These addresses can be used to identify the infrastructure an attacker is using for their campaign.
These artefacts can present themselves as C2 traffic for example.
TTP
Tools
Network
Domain Names
IP addresses
Hash values